Seguridad de la Información y Gobierno de TI

Conceptos fundamentales para desarrolladores de software

Made with GAMMA

¿Qué es la Seguridad de la Información?

La seguridad de la información es el conjunto de medidas y controles que protegen los activos digitales de una organización contra accesos no autorizados, uso indebido, divulgación, alteración o destrucción.

En el desarrollo de software, esto implica implementar prácticas seguras desde la fase de diseño hasta el despliegue y mantenimiento del sistema.

Made with GAMMA

Los Tres Pilares de la Seguridad

Confidencialidad

Garantiza que la información solo sea accesible para personas autorizadas. Se implementa mediante cifrado, control de accesos y autenticación.

Integridad

Protege la exactitud y completitud de los datos. Asegura que la información no sea modificada sin autorización durante su almacenamiento o transmisión.

Disponibilidad

Garantiza que los sistemas y datos estén accesibles cuando sean necesarios. Incluye medidas contra ataques de denegación de servicio y planes de contingencia.

Made with GAMMA

Caso Real: Sesión Abierta

1

Situación

Un desarrollador abandona su puesto sin cerrar sesión en el sistema de gestión de proyectos.

2

Explotación

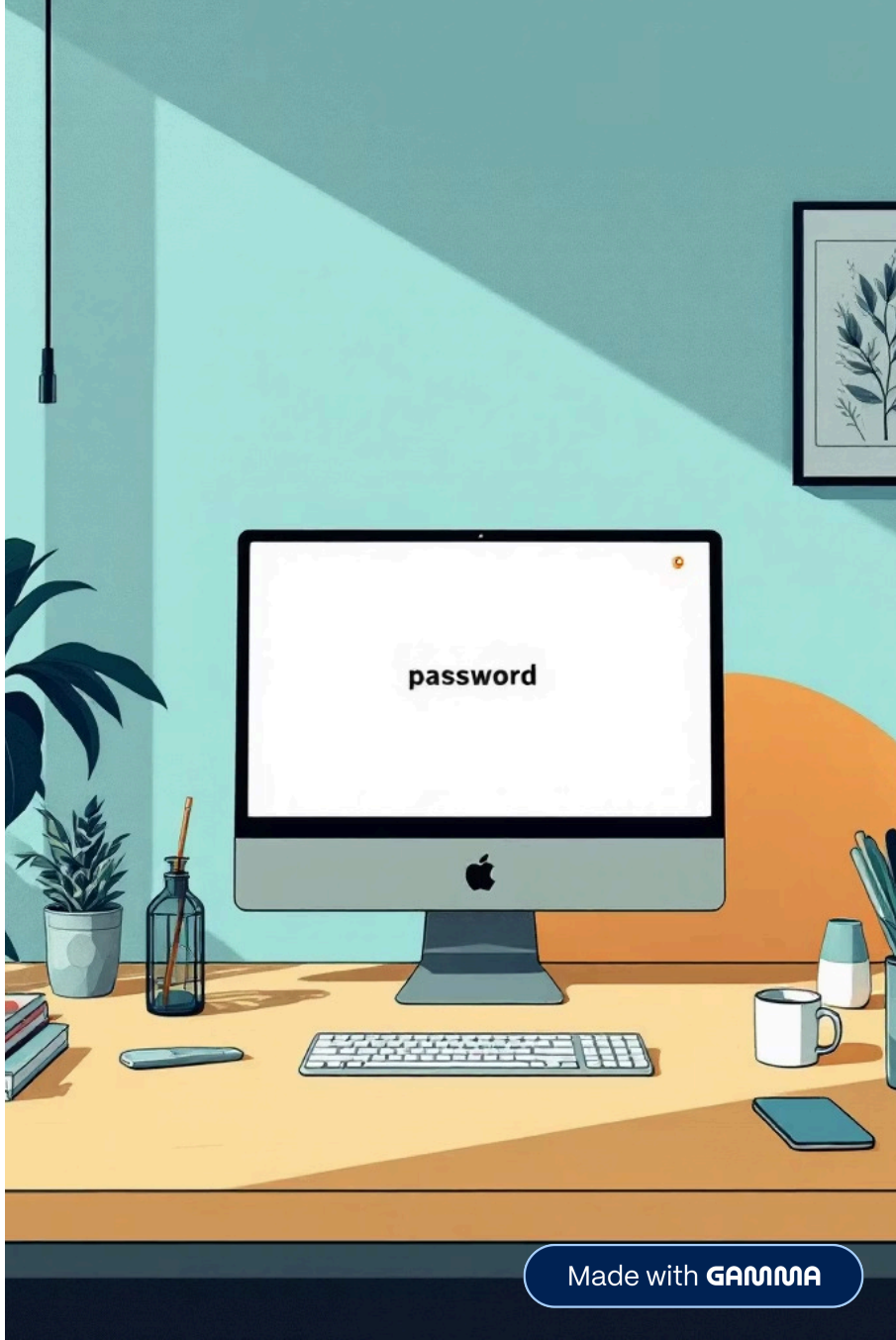
Un usuario malicioso accede a la cuenta y modifica información confidencial del proyecto.

3

Consecuencias

Pérdida de integridad, compromiso de datos sensibles y posible paralización del trabajo.

Lección aprendida: Implementar bloqueo automático de sesión tras periodos de inactividad y educar en hábitos de seguridad básicos.



Made with GAMMA

ISO/IEC 27001: La Norma de Referencia

Objetivo Principal

Establecer, implementar, mantener y mejorar continuamente un Sistema de Gestión de Seguridad de la Información (SGSI) que proteja los activos de información de la organización.

Enfoque

Adopta un enfoque basado en riesgos, permitiendo a las organizaciones identificar, evaluar y tratar los riesgos de seguridad de forma sistemática.

Made with GAMMA

Sistema de Gestión de Seguridad de la Información (SGSI)

El SGSI es un marco estructurado para gestionar la seguridad de la información de forma sistemática y continua.

Planificar

Identificar riesgos y establecer objetivos de seguridad

Hacer

Implementar controles y medidas de seguridad

Verificar

Monitorear, auditar y evaluar el cumplimiento

Actuar

Mejorar continuamente el sistema

Made with GAMMA

Controles de Seguridad Clave

Control de Accesos

Define quién puede acceder a qué recursos mediante políticas de autorización. Implementa el principio de mínimo privilegio: cada usuario solo tiene acceso a lo estrictamente necesario.

Autenticación

Verifica la identidad de los usuarios mediante contraseñas, tokens, biometría o autenticación multifactor. Es la primera línea de defensa contra accesos no autorizados.

Gestión de Riesgos

Identifica, evalúa y prioriza amenazas a la seguridad. Permite tomar decisiones informadas sobre dónde invertir recursos en protección y mitigación.

Auditoría

Registra y revisa actividades para detectar incidentes, cumplir normativas y verificar que los controles funcionan correctamente. Proporciona trazabilidad completa.

Made with GAMMA

COBIT: Gobierno de TI

¿Qué es COBIT?

Control Objectives for Information and Related Technologies es un framework de gobierno de TI desarrollado por ISACA. Ayuda a las organizaciones a alinear las TI con los objetivos de negocio y gestionar riesgos y recursos de forma efectiva.

Importancia para Desarrolladores

Proporciona un lenguaje común entre desarrolladores, gestores y auditores, facilitando la comunicación sobre seguridad y cumplimiento normativo.

Made with GAMMA

Principios Clave de COBIT

1

Alineación Estratégica

Las TI deben apoyar los objetivos del negocio. Los desarrolladores deben entender cómo sus sistemas contribuyen a la estrategia organizacional.

2

Entrega de Valor

Maximizar el retorno de inversión en TI. Implementar soluciones que aporten valor real, no solo tecnología por tecnología.

3

Gestión de Riesgos

Equilibrar oportunidades y amenazas. Identificar riesgos técnicos y de seguridad desde el diseño, no como añadido posterior.

4

Optimización de Recursos

Utilizar eficientemente personas, tecnología y procesos. Evitar duplicidades y maximizar el aprovechamiento de inversiones existentes.

Made with GAMMA

Buenas Prácticas para Desarrolladores

01

Aplica principios de diseño seguro desde el inicio

02

Implementa validación de entrada y salida de datos

03

Usa cifrado para datos sensibles en tránsito y almacenamiento

04

Mantén dependencias actualizadas y audita vulnerabilidades

05

Implementa logging y monitoreo para detectar incidentes

06

Participa en auditorías y revisiones de seguridad

Conclusiones

La seguridad no es un módulo a añadir al final, sino una disciplina integrada en todo el ciclo de desarrollo. Conocer ISO 27001 y COBIT permite a los desarrolladores contribuir activamente a la protección de información y al gobierno de TI efectivo.

Made with GAMMA

¡Muchas Gracias!

Por su atención. La seguridad de la información es un esfuerzo continuo.

Made with GAMMA